

Concepts of Cybersecurity

Individual Project

Security Risk Assignment Report

AgeWell Innovations – Digital Transformation Initiative

1. Executive Summary

This report gives AgeWell Innovations a full cybersecurity risk assessment as it works on a digital transformation project. The project includes the use of AI powered remote access tools and the use of partially managed personal devices by caregivers who work in the home. The goal of these changes is to make services better, make data more accurate, and make operations run more smoothly.

Because client data is sensitive and digitization makes it more vulnerable, a thorough assessment of possible threats is needed. The report lists some of the most serious risks, such as unauthorized access to data, AI misuse, data leaks, malware infections, and phishing attacks. It gives useful advice like Mobile Device Management (MDM), two factor authentication, monitoring AI use, encryption, and cybersecurity training.

The assessment uses a qualitative, threat-based method that ranks risks by how likely they are to happen and how bad they will be so AgeWell can focus on its most important weaknesses. The final recommendations should be useful, affordable, and easy to put into action within the current structure of the organization. By following the suggested risk treatments, AgeWell Innovations can make sure that the switch to digital operations goes smoothly and that its clients are safe while still following all the rules.

2. Introduction / Context Establishment

Goal and Attention:

The goal of this report is to look at the cybersecurity risks that come with AgeWell Innovations planned digital transformation. It will focus on the malicious cyber threats that come with AI tools and personal devices that are only partially managed. The evaluation takes into account the organization's goals, operational needs, and obligations to protect data.

Giving caregivers AI tools and some control over their devices is part of the digital transformation. This will make them more productive and help them give more personalized care. But this creates new weaknesses that need to be fixed before they can be used by bad actors.

Aligning Business Goals:

Moving from paper-based to digital processes fixes problems and makes it easier to get to data in real time. But it also makes cybersecurity harder, which could put sensitive information's privacy, integrity, and availability at risk. AgeWell's mission is to provide high-quality care for the elderly, and making sure that deployment is safe helps with that.

Key business objectives include:

- Enhancing care quality through better access to client information
- Reducing administrative overhead for carers
- Protecting sensitive personal and medical data from unauthorized access
- Building trust among clients and stakeholders

Legal and Compliance Constraints:

AgeWell's operations must adhere to national privacy and cybersecurity frameworks:

- Privacy Act 1988 (Australia): Governs how personal information must be handled
- Australian Privacy Principles (APPs): Outlines data security, access, correction, and accountability
- Notifiable Data Breaches (NDB) Scheme: Requires notification to affected individuals and the OAIC in the event of data breaches

Failure to comply can result in reputational harm, legal penalties, and loss of stakeholder confidence.

Risk Evaluation Criteria:

This assessment uses a qualitative, threat-based approach with risk measured by:

- Likelihood: Probability of occurrence (Low, Medium, High)
- Impact: Severity of potential damage (Low, Medium, High)
- Risk Level: Combined result of likelihood and impact, mapped on a risk matrix

The Report's Structure:

The executive summary, context setting, risk assessment, risk treatment recommendations, and evaluation comprise the report's five sections. Each section offers technical insight for cybersecurity staff to implement while also assisting the board in making well-informed, risk aware decisions.

3. Risk Assessment

3.1 Risk Identification

The five major risks listed in the following table are all the result of malevolent adversaries and are most pertinent to AgeWell Innovations' digital transformation:

Risk ID	Description of Risk
R1	Unauthorized use of personal devices to access client data
R2	Insiders' manipulation or abuse of AI systems
R3	Data leakage via an unprotected network or inadequate encryption
R4	Infection with malware or ransomware via unmanaged applications
R5	Phishing and social engineering attacks directed at caregivers

These hazards are a combination of human and technological weaknesses. The confidentiality, availability, and integrity of vital systems and data all fundamental principles of cybersecurity are directly threatened by each of them.

3.2 Risk Analysis

Every risk that was found was examined using a qualitative method, taking into account both its possible business impact and its probability of happening. A number of variables were taken into account, including system exposure, threat motivation, and current security measures.

Risk	Likelihood	Impact	Risk Level
R1: Unauthorized entry using personal electronics	High	High	Critical
R2: Insider abuse of artificial intelligence	Medium	High	High
R3: Unsecured networks leaking data	High	Medium	High
R4: App-based malware	Medium	Medium	Medium
R5: Attacks using phishing	High	Medium	High

3.3 Risk Evaluation

The NIST and ASD frameworks' best practices served as the guidelines for this risk assessment procedure. It only concentrates on dangers posed by malevolent enemies. To ensure practical mitigation within a reasonable budget and operational scope, the evaluation was restricted to five risks.

The following factors influenced risk prioritization:

- Possibility of noncompliance with regulations
- Damage to one's reputation due to data breaches
- Disruption to aged care operations

4. Risk Treatment / Recommendations

Summary

Every risk that has been identified has been linked to suitable treatment plans in accordance with industry norms. A combination of behavioral (user reliant) and technical (enforced) controls are used as treatments. AgeWell's distinct care environment is catered for in these solutions.

Risk	Recommended Controls	Control Type
R1	Containerization combined with mobile device management (MDM) Policies for device approval The ability to wipe remotely	Enforced
R2	Role-based access controls Monitoring of AI tool usage Log audits Anomaly detection	Enforced
R3	AES-256 encryption Secure network configurations Virtual private network (VPN) for remote access	Enforced
R4	Regular compliance checks Anti malware software App whitelisting	Enforced + User Reliant
R5	Phishing simulations Email filter systems Cybersecurity training	User Reliant

Justification of Controls

- In order to manage mixed-use personal devices and safeguard organizational data while maintaining user privacy, MDM and data containerization are crucial.
- The least privilege principle is upheld by RBAC and logging, which also offer accountability for the use of AI tools.
- Encryption and VPN safeguard data privacy while it's being transmitted.
- Malicious software cannot be installed thanks to antivirus software and app whitelisting.
- Proven techniques for lowering the probability of social engineering success include training and phishing simulations.

Residual Risk

Even though exposure is greatly decreased by these controls, risks still exist. These consist of:

- Undiscovered zero day vulnerabilities
- Policy infractions or human error
- Restricted access to third party networks and applications

AgeWell needs to set up a quick incident response plan and keep up constant monitoring in order to handle these.

5. Evaluation

Review of the Procedure

The risk assessment was conducted using a methodical process that included:

- Engagement of stakeholders (management, IT personnel, and carers)
- Risk identification and prioritization according to likelihood and impact
- Targeted controls are chosen according to their viability and operational alignment

This cooperative strategy produced results that were widely accepted and useful.

Communication and Consultation Plans

Stakeholder consultations were conducted at various points during the process to guarantee openness, get feedback, and promote support. Technical teams received regular briefings, and executives and the board received condensed summaries.

Monitoring and Review Suggestions

- Plan monthly system audits to find new dangers.
- Establish review meetings every three months to reevaluate risks.
- To record and gain insight from previous occurrences, keep an incident response log.
- Use automated monitoring tools to instantly identify anomalous activity.

Suggestions for Implementation

To guarantee a seamless adoption process:

- Begin with a small group of carers participating in a controlled pilot.
- Utilize manuals and training sessions to encourage the use of new tools.
- To maintain gains, include frequent refresher courses and feedback loops.

AgeWell can make its digital transformation a safe and customer focused success by implementing these steps.

6. References

1. Office of the Australian Information Commissioner (OAIC), Privacy Act 1988
2. Australian Signals Directorate (ASD), Essential Eight Maturity Model
3. NIST SP 800-30, Guide for Conducting Risk Assessments
4. Smith, R. (2021). Cybersecurity for Healthcare. Elsevier
5. ISO/IEC 27001:2013, Information Security Management Systems